

Documentation Quality Compliance Checker

Ilona Brinkmeier · Wiebke Meyer · Carol Willing

Problem

Software teams in regulated or audit-heavy environments (healthcare, fintech, enterprise SaaS or critical infrastructure) often lose significant time during releases because documentation quality and compliance checks are manual, inconsistent and late in the delivery cycle.

Initial solution and audit scope

The **Doc Quality Compliance Checker** is a structured, workflow-oriented system that:

- Checks technical documents against governance and quality standards
- Improves consistency across SOP, architecture, and risk artifacts
- Shortens review cycles for QA, compliance, and audit teams
- Surfaces release-risk gaps earlier in the delivery cycle
- Improves traceability for approvals and governance decisions

High-level architecture

- Human operator
- Next.js frontend
- FastAPI backend
- PostgreSQL database
- Orchestrator and external agents
- Excellent documentation and production software engineering practices
- github.com/llobe/doc_quality_compliance_check

Privacy-focused audit

[View audit report →](#)

- End-to-end investigation of privacy risks across the stack
- User accounts, roles, and session data (GDPR-relevant)
- Document content and audit trails with business and personal data
- External LLM egress and telemetry expand the trust boundary

Top privacy risks

Priorities

- Egress traffic flow data to director and external models
- Application telemetry and workflow tracing
- Role-based access controls and GDPR compliance

Up next: In-depth risk analysis

- Sensitive data
- Why the risk matters
- Priority of the risk
- **Mitigations** for each risk

Egress exposes privacy data



External model

- **Data**
 - Names, emails, stakeholder assignments, reviewer identifiers, document passages copied into prompts, generated summaries that may restate personal data
- **Why sensitive**
 - Leaves the primary application context during model inference (current external-provider path)

Observability traces

- **Data**
 - provider, model_used, trace_id, correlation_id, latency/tokens, rich payload entries, prompt/output snapshots
- **Why sensitive**
 - Enables reconstruction of **who** triggered **what** model action and **when**
 - Can become re-identifiable when combined with audit tables

Model credentials

- **Data**
 - API keys, adapter routing flags, provider selection settings
- **Why sensitive**
 - Compromise enables data exfiltration or unauthorized model usage

Mitigation: Egress traffic flow data to orchestrator and models



TODO: add happy mitigated image here



Audit logs/reports and telemetry expose privacy data



LLM quality observations

- **Data**
 - ***payload.provider***, ***payload.model_used***, ***payload.llm_temperature***
 - ***payload.llm_prompt*** — document text, stakeholder names, reviewer assignments
 - ***payload.llm_output*** — compliance summaries that may restate personal context
- **Why sensitive**
 - Prompt context from user documents with names, emails, project identifiers, and business-sensitive content
 - Output may restate that content; both are persisted to a queryable table

Audit event payload

- **Data**
 - payload.roles (user role at login), payload.remember_me flag, event-specific context fields, free-form data from orchestrator or Skills API callers
- **Why sensitive**
 - Append-only and intended for long retention
 - No technical control prevents callers from writing personal data into the payload column
 - Combined with actor_id (user email) it forms a rich personal profile

OpenTelemetry span attributes

- **Data**
 - HTTP path attribute (e.g., */api/v1/documents/doc-abc123* — document ID in path), user_agent, http.method, http.status_code, trace_id / span_id
- **Why sensitive**
 - When TRACING_EXPORTER=otlp, path values can embed document or session identifiers
 - User-agent can contribute to fingerprinting

Frontend CSV export

- **Data**
 - Exported observability ***prompt_output_pairs.csv*** with prompt, output, source_component, trace_id, timestamps
- **Why sensitive**
 - Created on the user's local filesystem
 - Outside system access controls, retention policy, and audit log
 - May contain personal data from documents processed during the export window

Mitigation: Application telemetry and workflow tracing

- Recommend following OpenTelemetry best practices for handling sensitive data
- Follow the principle of data minimization, where possible.
- While it may not be optimal, try hashing user information and id and delete unhashed data.
- Consider using OTel's `redaction` processor between collection and export
- Apply similar principles to audit logs and reports

TODO: add happy mitigated image here



Misconfigured and stale controls give access to private data



Sensitive data

- User identity in session store
 - **Data:**
 - user_email (primary identifier), user_org, session session_id, expires_at, last_seen_at
 - **Why Sensitive:**
 - Directly identifies users and links their organisational role to access patterns and audit trails
 - Retained in PostgreSQL with no visible TTL-based purge policy

- Role assignments and permission scope
 - **Data:**
 - user_roles array per session row (e.g., ["qm_lead"], ["auditor"]), org isolation field user_org
 - **Why Sensitive:**
 - Reveals organisational responsibilities and access privileges
 - Can be used for social engineering or targeted attacks
 - GDPR data minimisation applies

- Bootstrap/MVP credentials in environment configuration
 - **Data:**
 - AUTH_MVP_EMAIL, AUTH_MVP_PASSWORD, AUTH_MVP_ROLES, AUTH_MVP_ORG (env vars)
 - SECRET_KEY (API key secret)
 - **Why sensitive:**
 - Compromise of bootstrap credentials gives attacker a fully provisioned account with configurable roles
 - SECRET_KEY grants service-client access to skills and observability

- Access decision and audit context not separately persisted
 - **Data:**
 - Which role accessed which route at what time
 - 403 access denials
 - service-client route usage with payload summary
 - **Why sensitive:**
 - Absence of access-decision audit log prevents retrospective investigation of data-access incidents
 - Required for GDPR Art. 30 record of processing activities and breach response

Mitigation: Role-based access controls and GDPR compliance



Role-based access control



Role-based access control

Recommendations

- Top priority going forward
 - Why it matters
- Fit with company and risk strategy
 - Value created

Top priority going forward

- Continue to refine the automation and human interaction
- Focus on reducing manual work while meeting the standard
- Maintain and enhance the tool for further efficiency gains and respond to regulatory changes

Why it matters

- Too much for any one human to analyze 1000 page document
- Reduces time to analyze document from weeks and months
- Flexibility to implement changes if directives change
- Reduces the need for expensive specialists to work on repetitive tasks
- Offers basic insights on what has changed, where changed, and policies affected

Fit with company and risk strategy

- Complies with GDPR / BSI in Germany regulations for software rules
- Main regulatory points are addressed in workflow and prepares for external audits

Value created

- Company is prepared for being audited by external agencies
- Cost savings from moving to internal models instead of using external services
- Maximize the human's impact for Human-in-the-loop by reducing toil and increasing time to focus on complex business cases

Questions & answers

- Audit scope and findings
- Risk prioritization and trade-offs
- Mitigations and open items

Thank you

Ilona Brinkmeier · Wiebke Meyer · Carol Willing

Privacy audit

<https://willingc.github.io/compliance-checker/>

Application

https://github.com/IloBe/doc_quality_compliance_check

Appendix

- DocQuality Bridge workflow screens
 - DocQuality Admin screens
- DocQuality Compliance standards screens

Bridge workflow — orchestration



Bridge workflow — run steps 1–2



Bridge workflow — run steps 4–4b



Bridge workflow — run step 5



Admin — governance & access control



Compliance standards — mandatory & optional



Mandatory compliance standards



Optional compliance standards